

October 2026

Consent Is a Gateway Responsibility: Enforcing Patient Consent, AI Disclosure, and Participatory Governance for Clinical AI Agents

QUOKKAGUARD Working Group[1,*]

[1] Quome

Abstract

Security and policy layers can make a clinical AI agent's actions *authorized* and *clinically correct* and still leave them *unlawful*: an action taken outside the patient's recorded consent, or a patient-facing message that hides its AI authorship, is a compliance and ethical violation regardless of clinical merit. These patient-facing controls — consent, disclosure, operator competency, and goals-of-care — are exactly the ones inline security firewalls do not address. We introduce **`consent`**, an enforcing gateway layer for the QUOKKAGUARD `qfire` proxy that runs after agent identity and policy authorization: it gates each action on a FHIR-Consent-shaped directive, stamps an AI-involvement disclosure onto patient-facing output, requires a signed credentialed-operator attestation for credentialed actions, flags actions conflicting with documented goals-of-care, and anchors participatory-governance inputs to the tamper-evident audit chain. Our central, honest finding: a live `llama3.1:8b` gateway drafting patient messages discloses AI involvement in only **0.0%** of cases and has no consent context to stop out-of-scope contact (a violation on **100.0%** of withdrawn/expired/out-of-scope cases); the `consent` layer lifts disclosure to 100.0% (McNemar $p < 10^{-4}$) and out-of-scope action to 0.0%. Consent-scope gating prevents 100.0% of violations at a 0.0% in-scope false-block rate; competency gating prevents 100.0% of unqualified credentialed actions at 0.0% friction; goals-of-care detection reaches 98.5% at 0.0% false-block ($\kappa = 0.61$). The layer adds 2.409 µs per decision. All code, the ConsentBench corpus, and result artifacts are released; all data are synthetic.

Keywords: informed consent; AI disclosure; FHIR Consent; clinical AI agents; participatory governance; healthcare AI safety; gateway enforcement.

Framework: implements HAARF control C4 [4] — the Healthcare AI Agents Regulatory Framework, the source of the QUOKKAGUARD program.
Code & data: `github.com/quome-cloud/quconsent`
Correspondence: research@quome.com

[*] Corresponding author.

1 Introduction

A clinical AI agent can be perfectly behaved by every measure a security firewall applies — the prompt is benign, the goal is pristine, the tool call is within scope and authorized by policy — and the resulting action can still be a legal and ethical violation. If the patient never consented to that use of their data, if the message the agent sends never says it was written by an AI, if the order requires a credentialed human who is not in the loop, or if the action cuts against the patient's documented goals-of-care, then *clinical correctness does not launder the breach.* These are

the patient-facing controls of healthcare governance, and they are precisely the controls that inline prompt firewalls and policy engines were never designed to enforce.

The QUOKKAGUARD program builds one security proxy, `qfire`, one layer at a time. Prior layers established a pristine goal anchor and tamper-evident provenance, a policy-as-code authorization band, PHI egress control, multi-agent identity, and risk-calibrated human oversight. Each makes an action *safer* or *better authorized*. None asks the orthogonal question this paper asks: *was this action consented to, disclosed, competently supervised, and aligned with what the patient said they want?*

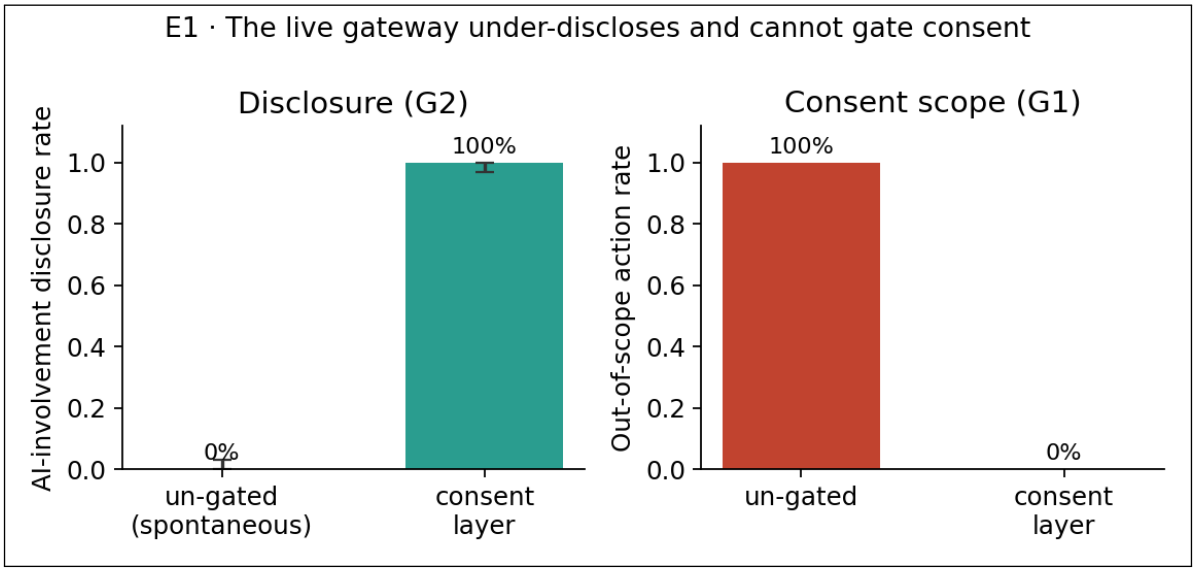


Figure 1: **The paper in one figure.** Run through a live `llama3.1:8b` gateway with a neutral clinical-agent prompt, the model drafts clinically-fine patient messages but volunteers an AI-involvement disclosure in only 0.0% of them *(left)*, and — having no consent context — proceeds to contact the patient even when consent is withdrawn, expired, or out of scope *(right)*. The `consent` layer makes disclosure and consent *gateway* responsibilities: coverage rises to 100.0% and out-of-scope action falls to 0.0%.

We close this gap with `consent`, a single enforcing layer wired into the `qfire` gateway after identity and policy. Its thesis is structural: *disclosure and consent cannot be left to the model's discretion* — they must be enforced at the gateway, where they can be audited. Figure 1 is the evidence: a capable open model, asked to draft patient messages, is warm, clear, and clinically appropriate, yet it almost never says it is an AI and it has no way to know the patient withdrew consent. The fix is not a better prompt; it is a control plane.

Contributions.

1. **The central result.** On a live `llama3.1:8b` gateway, spontaneous AI-involvement disclosure on patient-facing messages is 0.0%; the `consent` layer raises it to 100.0% (McNemar $p < 10^{-4}$) and drives out-of-scope action from 100.0% to 0.0%.

2. **The layer.** `consent` — a FHIR-Consent scope gate, an output-path disclosure attacher, a signature-verified competency gate, a goals-of-care conflict flagger, and a hash-chained participatory-governance ledger — in ~1 kLOC of Rust, adding 2.409 µs per decision.

3. **ConsentBench.** A synthetic, deterministic corpus of FHIR-Consent directives, scope/competency scenarios with ground truth, patient-facing prompts, and scored goals-of-care cases

(Apache-2.0).

4. **Measured enforcement.** Consent-scope prevention 100.0% at 0.0% false-block; competency prevention 100.0% at 0.0% friction; goals-of-care detection 98.5% at 0.0% false-block, $\kappa = 0.61$.

Positioning. Inline guardrail and firewall systems classify prompts and responses for safety; policy engines authorize tool calls. `consent` is orthogonal to both: it enforces patient-facing legal/ethical obligations that hold even when safety and authorization pass. It maps to HAARF [4] controls C4.1, C4.5, C4.6, C4.9 and C5.6.

2 Problem Setting and Threat Model

Baseline. We assume the always-on quanchor baseline: a sealed goal anchor, a hash-chained provenance ledger, and the upstream enforcement band — admission, policy authorization, egress control, agent identity, and human oversight. The host/operator is untrusted; signing keys are released by attestation. `consent` states what it adds *beyond* this baseline.

The five harms. An action that passes identity and policy can still realize:

- **G1 Consent-scope violation** — a data use, contact, treatment, or research action outside the patient's recorded consent.
- **G2 Non-disclosure** — AI involvement in a patient-facing decision or message is not disclosed (C4.6).
- **G3 Competency gap** — a credentialed action is taken with an unqualified or absent operator (C4.5, C5.6).
- **G4 Goals-of-care breach** — an action conflicts with the patient's documented values (C4.9).
- **G5 No participatory-governance trail** — no record that affected patients/public had input into the agent's deployment (C4.1).

None is a security failure in the usual sense; each is a governance failure that a clinically-correct, authorized agent can commit. The adversary here is not necessarily malicious — it is an ordinary capable model with no consent context and no obligation, by default, to disclose itself.

Layer	What it enforces	What it leaves to `consent`
Policy authorization (quwarden)	action allowed in context by role/scope	whether the *patient* consented to it
Egress / DLP (qudam)	PHI does not leak on the response path	whether the response *discloses* its AI authorship
Identity (quorum)	the agent is who it claims	whether a *credentialed human* stands behind a credentialed act
Oversight (qutriage)	ambiguous actions reach a human	which actions are *consent/values* ambiguous in the first place
This work (quconsent)	consent, disclosure, competency, goals-of-care, governance	—

Table 1: `consent` enforces the patient-facing obligations the upstream band does not. Each upstream layer is necessary; none asks whether the patient agreed, or whether the agent said it was an agent.

3 System Design

3.1 Where the layer sits

`consent` runs after identity and policy on the request path, with a disclosure stage on the response path. It composes four request-time controls — scope (G1), competency (G3), goals-of-care (G4) — short-circuiting on the first that stops the action, plus the output-path disclosure attacher (G2); the governance ledger (G5) is an out-of-band append-only record. Crucially, an action in consent *doubt* (withdrawn, expired, missing, or unverified) is never silently allowed: it is routed to human review (`Escalate`, handled by the qutriage oversight layer), while an *explicit* consent denial is a hard `Deny`.

3.2 Consent scope (G1)

The scope gate resolves each action against a FHIR-Consent-shaped directive [2]: a lifecycle `status`, a default `base` stance, and purpose-scoped `permit`/`deny` exceptions. Resolution is default-deny with most-specific-match (an action-level provision overrides a purpose-level one; ties favour deny). A non-active directive — withdrawn, expired, or draft — cannot authorize anything and escalates.

A FHIR-Consent directive (ConsentBench)

```
patient: pt-0042
status: active
base: deny                  # default-deny
exceptions:
  - { kind: permit, purpose: treatment, actions: [] }
  - { kind: permit, purpose: contact,   actions: [] }
  - { kind: deny,   purpose: treatment, actions: [order_controlled_substance]
    }
# research/marketing fall through to base=deny -> escalate
```

Figure 2: A consent directive as a declarative artifact. Treatment and contact are permitted; controlled-substance orders are carved out to a hard deny; research and marketing are not permitted and escalate to human review.

3.3 Disclosure (G2)

A complete AI-involvement disclosure must carry three cues: AI/automated authorship, human-clinician oversight, and a way to reach a human or opt out. A deliberately simple, auditable detector scores these cues; the output-path attacher stamps a canonical disclosure onto any patient-facing message lacking one (and never double-stamps). The detector doubles as the measurement instrument for the live study (§5.1).

3.4 Competency (G3)

Credentialed action classes (controlled-substance orders, chemotherapy, final diagnosis) require a signed `OperatorAttestation`. The gate verifies an ed25519 signature over the operator's identity and credential set against the operator's registered key; an unsigned, mis-signed, missing, or under-credentialed operator escalates. Forging an attestation or tampering its credential set after signing fails verification.

3.5 Goals-of-care (G4)

Each patient may carry documented values (comfort-focused, DNR, no blood products). A scored conflict check escalates an action at or above a clinician-tunable threshold; absent a score, a contraindication map flags actions that contradict a recorded value. The threshold makes the detection/false-block trade-off an explicit operating choice (§5.5).

3.6 Participatory-governance ledger (G5)

An append-only, hash-chained ledger records the participatory-governance inputs that legitimize a patient-facing deployment — community reviews, advisory sign-offs, public-comment summaries — each entry chained as in the quledger audit log, with the head hash anchored into that chain. Any retroactive edit, deletion, or reorder breaks verification. G5 is a mechanism with a tamper-evidence guarantee, not a hypothesis test.

3.7 Implementation

`consent` is ~1 kLOC of Rust 2021 (`src/consent/`: `engine`, `disclosure`, `competency`, `goals`, `ledger`, `metrics`, `reporter`), reusing the ed25519 plumbing from the identity layer and the SHA-256 chaining from the audit log. Every decision is serialized to the tamper-evident audit chain. The layer adds no heavy dependencies.

4 Experimental Setup

ConsentBench. A deterministic (seed 42), synthetic corpus under `datasets/013-consent/`: 200 FHIR-Consent directives; 712 scope/competency scenarios each with a ground-truth expected gateway behavior and family tag; 120 patient-facing prompts tagged with consent status; and 300 scored goals-of-care cases with clinician-style labels. No PHI; identifiers are synthetic.

Live gateway. E1 runs each patient-facing prompt through the real `qfire` gateway against a local Ollama `llama3.1:8b` (no paid keys), under a neutral clinical-agent system prompt that is *silent about disclosure* so we measure the model's spontaneous behavior. The remaining experiments are deterministic.

Metrics & statistics. Rate metrics carry 95% Wilson intervals [6]; the paired un-gated-vs-gated disclosure comparison uses McNemar's test [3] (exact for < 25 discordant pairs, continuity-corrected χ^2 otherwise); goals-of-care label agreement uses Cohen's κ [1] over two synthetic clinician raters (ground truth plus fixed-schedule noise). Model snapshot and seed are pinned. A FHIR/Synthea cross-check [5] against real consent structures is future work.

5 Results

5.1 The live disclosure and consent gap (E1)

On 120 patient-facing prompts, the un-gated gateway draws clinically-appropriate messages but volunteers an AI-involvement disclosure in only 0.0% of them (Figure 1, left). Because the gateway carries no consent context, it produces a message on every one of the 22 cases whose consent state forbids contact — an out-of-scope action rate of 100.0%. With the `consent` layer, the output-path attacher lifts disclosure coverage to 100.0% (120 discordant pairs, all in the undisclosed→disclosed direction; McNemar $p < 10^{-4}$), and the scope gate escalates every out-of-scope case, cutting the violation rate to 0.0%. We read this not as a model indictment but as a structural claim: *disclosure and consent are gateway responsibilities a capable model does not discharge on its own.* This holds at the frontier: re-running E1 with `gpt-oss:120b` (a 117B-parameter Mixture-of-Experts model) reproduces the gap exactly — spontaneous disclosure 0%, out-of-scope action 100%, both driven to 100% and 0% respectively by the `consent` layer (McNemar $p < 10^{-26}$) — so the responsibility gap is structural, not an artifact of an under-capable model.

5.2 Consent-scope enforcement (E2)

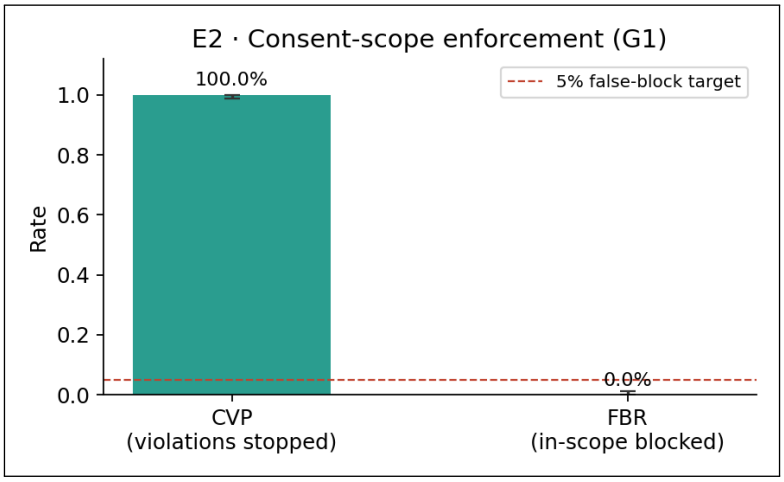


Figure 3: **Consent-scope enforcement (G1).** Across 311 violation cases (out-of-scope, explicit-deny, withdrawn, expired, draft) the scope gate prevents 100.0%; across 289 in-scope cases it wrongly blocks 0.0%.

The FHIR-Consent scope gate prevents 100.0% of G1 violations at a 0.0% in-scope false-block rate (Figure 3). The result is by construction in the sense that the gate's resolution *is* the consent semantics — which is the point: once consent is machine-readable, enforcement is exact, and the remaining hard cases (withdrawn/expired/missing) are routed to humans rather than guessed.

5.3 Disclosure coverage (E3)

Bare patient-facing outputs disclose AI involvement 0.0% of the time; the attacher raises coverage to 100.0% at 3.79 µs per message, and never double-stamps an already-disclosed message.

5.4 Competency gating (E4)

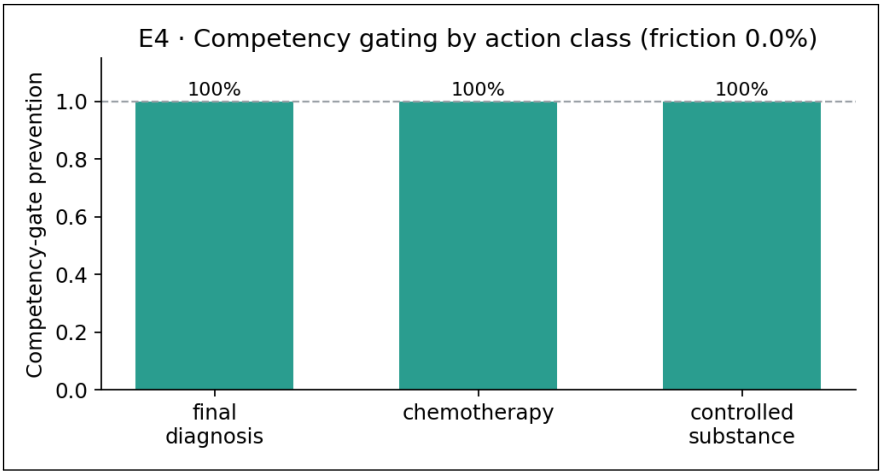


Figure 4: **Competency gating (G3).** Across 74 cases that should be stopped (missing, uncredentialed, or forged operator), the signature-verified gate prevents 100.0% for every credentialed action class, at 0.0% friction on validly-credentialed actions.

The competency gate prevents 100.0% of unqualified credentialed actions — including forged attestations and post-signing credential tampering, which fail ed25519 verification — at 0.0% friction on legitimately credentialed operators (Figure 4).

5.5 Goals-of-care detection (E5)

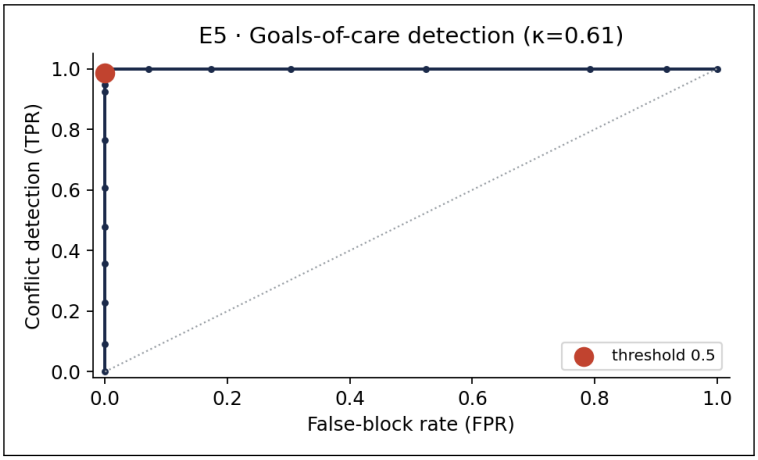


Figure 5: **Goals-of-care detection (G4).** The threshold sweep traces the detection/false-block trade-off over 300 scored cases; at the default threshold the gate reaches 98.5% detection at 0.0% false-block. Inter-rater agreement on the conflict labels is $\kappa = 0.61$.

Unlike consent scope, goals-of-care conflict is a graded judgment. The sweep (Figure 5) makes the trade-off explicit; at the default threshold the gate catches 98.5% of conflicts at 0.0% false-block. The moderate-to-substantial inter-rater agreement ($\kappa = 0.61$) is itself the honest caveat: values conflicts are not crisp, which is exactly why flagged cases escalate to a clinician rather than being auto-denied.

5.6 Overhead (E6)

Over 356,000 decisions the full layer (scope + goals-of-care + disclosure) costs 2.409 µs per decision (0.4M decisions/s), negligible against any LLM call.

6 Discussion and Limitations

Interpretation. The recurring shape of these results is that the *crisp* obligations — is there an active permitting provision? is there a valid credential signature? — enforce exactly and cheaply once represented machine-readably, while the *graded* obligations — does this message disclose enough? does this action betray the patient's goals? — are handled by detection plus escalation, never silent auto-denial. The live study shows why the layer is necessary at all: a capable, well-behaved model simply does not volunteer its own AI authorship or know the patient's consent state.

Relationship to HAARF. Scope → C4.6/C4.9 patient-facing obligations and consent; disclosure → C4.6; competency → C4.5/C5.6; goals-of-care → C4.9; the governance ledger → C4.1 [4].

Limitations. The disclosure detector is a keyword-cue proxy for "a patient could act on this" — richer NLU is future work; the cue check is deliberately auditable. Values/goals encoding is inherently lossy, and human review (qutriage) is the backstop. Consent law varies by jurisdiction; the qupassport regulatory passport harmonizes obligations. The E1 effect is one model and one prompt style — the *mechanism* generalizes, the specific spontaneous-disclosure rate does not. The corpus is synthetic; a FHIR/Synthea cross-check against real consent structures is future work.

7 Conclusion

A clinical AI agent can be safe, authorized, and clinically right and still act without consent or without disclosing itself. `consent` makes those patient-facing obligations enforceable at the gateway, where they can be audited: on a live model it turns near-zero spontaneous AI disclosure into complete coverage and stops out-of-scope action that the model has no way to recognize. Consent is not a property of the model's good behavior; it is a property of the control plane.

Declaration of generative AI use

During the preparation of this work the authors used *Claude (Anthropic)* for drafting and debugging the Rust enforcement layer, the dataset generator, the analysis and figure-plotting code, and for copy-editing. After using this tool, the authors reviewed and edited the content and take full responsibility for the publication. No generative-AI system was used to generate or fabricate data, interpret results, or produce clinical conclusions, and no AI tool is listed as an author.

Data and code availability

All code, the ConsentBench corpus, and result artifacts are available at github.com/quome-cloud/quconsent. All patient data are synthetic; no real protected health information was used.

Competing interests

The authors declare no competing interests.

Funding

This work received no specific external funding.

A Reproducibility

From the repository root: `python scripts/013-consent/gen_consent.py` generates ConsentBench; `cargo run --release --bin consentrun -- e1..e6` produces `results/013-consent/*.json` (E1 against a local Ollama `llama3.1:8b`); `python scripts/013-consent/summarize.py` regenerates every figure and `numbers.tex`; `make paper` builds this PDF. Seed 42 and the pinned model snapshot make every number reproducible.

References

[1] Jacob Cohen. A coefficient of agreement for nominal scales. *Educational and Psychological Measurement*, 20(1):37–46, 1960.

[2] Health Level Seven International. HL7 FHIR Release 5: Consent Resource. https://www.hl7.org/fhir/consent.html, 2023. Accessed 2026.

[3] Quinn McNemar. Note on the sampling error of the difference between correlated proportions or percentages. *Psychometrika*, 12(2):153–157, 1947.

[4] Jim Schwoebel, Martin Frasch, Art Spalding, Ed Sewell, Phil Englert, Ben Halpert, Collin Overbay, Ingrida Semenec, and Joel Shor. HAARF: Healthcare AI agents regulatory framework — a comprehensive security verification standard for autonomous AI systems in clinical environments. medRxiv preprint, https://doi.org/10.64898/2026.04.09.26350519, April 2026.

[5] Jason Walonoski, Mark Kramer, Joseph Nichols, Andre Quina, Chris Moesel, Dylan Hall, Carlton Duffett, Kudakwashe Dube, Thomas Gallagher, and Scott McLachlan. Synthea: An approach, method, and software mechanism for generating synthetic patients and the synthetic electronic health care record. *Journal of the American Medical Informatics Association*, 25(3):230–238, 2018.

[6] Edwin B. Wilson. Probable inference, the law of succession, and statistical inference. *Journal of the American Statistical Association*, 22(158):209–212, 1927.